PHP2SHELL · NODE2SHELL · CVSS 9.2

A model found the PHP hole

Unauthenticated RCE in every version since 5.4 — and Node.js the same night

FALLOUT IN 24 HOURS

32

UK gov services offline

pre-emptively; the Dutch NCSC took down its own site

WHAT IS ACTUALLY BROKEN

- PHP: use-after-free under memory pressure
- default Apache mod_php, not an exotic setup
- Node.js: OOB write in the Brotli decoder
- any endpoint that decompresses input

PATCH TODAY

- PHP 8.5.12 / 8.4.27 / 8.3.36 / 8.2.35
- Node 22.23.4 / 24.22.1 / 26.12.1
- no workaround: zlib ships in the binary
- cannot patch? pull it off the public net

THE EMBARGO COLLAPSED

Exploitation began four days before public disclosure

per AWS; CVE ids leaked on Oct 20, the patch shipped ahead of plan

TAKEAWAY

"We'll patch it next sprint" is no longer a strategy

t.me/aidacode